Monthly Intelligence Dispatch

April 2018

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly overview of the international company Group IB, which specializes in the prevention of cyber threats and in the development of information security products. The objective of the Dispatch is to inform readers of current cyber threats, attacks by criminal groups, leaks and new malware. This report includes news of arrests and legal actions against members of hacker groups, as well as short-term forecasts and warnings that will allow you to take timely measures to protect yourself against cyber threats. Group-IB's MTID is prepared for in-house use only and is not intended for distribution.

Key Findings

- Group-IB has released a report '**Cobalt: Evolution and Joint Operations**', for the first time, publicly disclosing the joint operations of the Cobalt Group and Anunak (Carbanak) and providing in-depth analysis of their key attacks and tools.
- Servers compromised by Black Energy APT group (also known as Dragonfly, Energetic Bear) to use them in waterhole attacks have been identified in Russia, Ukraine, Europe and the USA.
- A new backdoor for macOS used by OceanLotus (APT32) for cyber espionage has been detected.
- Hackers from Orangeworm have installed the Trojan.Kwampirs backdoor in international healthcare corporations in the USA, Europe and Asia.
- North Korean hackers have conducted a series of cyberattacks on clients of cryptocurrency exchanges and financial companies in 17 countries as part of their campaign called GhostSecret Operation.
- Russian FinCERT has issued two advisories warnings banks of the activities of the Silence group and the use of the Dimnie Trojan for theft of money and confidential information.
- In the USA, attackers deployed SamSam ransomware in hospitals and schools, which decided to pay for the return of their encrypted data.
- Source code of Treasure Hunter, a malicious program for POS terminals, was published on an underground forum in April 2018.
- Early this year, at least three European financial institutions suffered DDoS attacks using a new variant of the Mirai botnet.
- Europol and the Dutch police have taken down webstresser.org, the world's biggest DDoS-for-hire service that helped cyber criminals launch over 4 million attacks.

Main Focus: Cobalt

Cobalt

Group-IB's Threat Intelligence experts have released a report '**Cobalt: Evolution and Joint Operations**', for the first time, publicly disclosing the joint operations of the Cobalt Group and Anunak (Carbanak) and providing in-depth analysis of their key attacks and tools.

On March 26, Europol reported that the leader of the Cobalt hacking group, accused of stealing about EUR 1 billion from 100 banks in 40 countries, was arrested in Alicante, Spain. In spite of this arrest, Group-IB has tracked new phishing letters and therefore it is far too soon to dismiss Cobalt.

The report says that the Cobalt group conducted its first successful attacks and thefts via SWIFT in the spring of 2016 in Hong Kong and then in Ukraine. After that, Cobalt switched to easier and safer attack and theft schemes via card processing and ATM control networks. During their attack on First Bank in Taiwan, the hackers managed to steal $2 million from about thirty ATMs. In September 2016, they managed to break into a bank in Kazakhstan and steal about $600,000 via card processing.

Throughout the last two years of activity, Cobalt's has been highly active with group members continuously testing new methods and tools. In addition to banks, Cobalt has also conducted 'supply chain' attacks. In February 2017 Group-IB responded to a successful attack on a system integrator which Cobalt used as a vehicle to conduct further attacks on organizations in Russia and former CIS countries.

In early 2017, Cobalt enlisted a team of developers to create and test new tools. For example, Cobalt used a modification of the infamous **Petya Ransomware** to disrupt the bank's networks. In December 2017, Cobalt returned to attacks on SWIFT – for the first time in Russia, they made a successful attack on a bank through SWIFT. In 2017, we identified communications between the Cobalt group and members of the Anunak group, who purportedly helped Cobalt to commit their first thefts through SWIFT. It explains a number of earlier incidents, where Cobalt's 'pattern' was supplemented with non-typical tools and methods that greatly complicated attribution. Cobalt has been preparing for new attacks since this spring. In spite of the fact that its leader had been arrested, Group-IB has tracked new phishing emails typical of Cobalt.

Main Events: Espionage, Sabotage, Leaks

Fancy Bear

Several LoJack agents (software for locating and locking stolen laptops) appear to be connected to servers controlled by Fancy Bear (APT28, Sofacy), according to experts at Netscout Arbor Networks. At least five LoJack agents point to four C&C servers, which were involved in previous Fancy Bear campaigns. **The experts suppose that the hackers installed a backdoor in certain LoJack copies to use it as a surveillance tool in their cyberespionage campaign.** It is worth reiterating that the Fancy Bear group is suspected of attacks on the French TV channel TV5 Monde, the Democratic National Committee, the German Parliament and ministries, and the World Anti-Doping Agency (WADA). According to the experts, Fancy Bear has recently been shifting the vector of its attacks from the NATO countries and Ukraine to ex-Soviet republics in Central Asia and to the Middle East and Far East. In March, experts detected hacker attacks launched by Fancy Bear against an undisclosed European government agency.

Black Energy

Experts analyzed numerous servers in Russia, Ukraine, Europe and the USA compromised by the Black Energy (Dragonfly, Energetic Bear) group. According to a Kaspersky Lab report, the majority of compromised servers were used in watering-hole attacks. **The compromised resources included the websites of an opposition party and a football club from Russia, a Ukrainian bank, an aerospace company from the UK, an industrial and investment group from Turkey, oil-and-gas companies from the USA, etc.** In March, the US Department of Homeland Security and the FBI released a joint technical warning about possible cyberattacks on critical US infrastructure conducted by the Black Energy group. It says that state-linked hackers are conducting multi-step campaigns to break into small commercial networks of the energy industry. The Black Energy group is known for successful attacks on the energy and financial systems in Ukraine in 2016. For example, the group uses tools that allow Remote terminal units (RTUs) responsible for the physical opening/closing of power grids to be remotely controlled. According to the experts, it is Black Energy that is responsible for the distribution of the NotPetya and BadRabbit ransomware that infected Ukrainian ministries, banks, airport and subway in 2017.

Main Events: Espionage, Sabotage, Leaks

IRGC

The US Justice Department accused nine Iranians of participating in a large-scale cyberespionage campaign. Since 2013, they have hacked and stolen electronic data from about 320 universities in 22 countries, including 144 universities in the USA. **The activity could cost universities $3.4 billion.** The US agency says that the accused attackers worked to benefit the government of Iran, particularly the Islamic Revolutionary Guard Corps (IRGC).

OceanLotus

Researchers at Trend Micro have detected a new backdoor for **MacOS** used by the OceanLotus (APT32) group. They have found this backdoor in MacOS systems which have the Perl programming language installed. The group has been known since 2012, targeting state-owned and private companies in Vietnam, the Philippines, Laos and Cambodia. Last year, according to the Volexity report, APT32 was found attacking members of the Association of Southeast Asian Nations (ASEAN), as well as journalists, dissidents, political and civic activists.

Main Events: Espionage, Sabotage, Leaks

Orangeworm

According to a Symantec report, hackers from the Orangeworm group have installed a custom backdoor called Trojan.Kwampirs in large international healthcare corporations that operate in the USA, Europe and Asia. Orangeworm has been observed conducting cyberespionage attacks since at least 2015. Most of its victims are from the US (17%), Saudi Arabia and India, as well as the UK, Turkey, Germany, Poland, Hong Kong, Sweden and France. The backdoor was originally used as a reconnaissance tool and, if a compromised computer contained data of interest, the backdoor was aggressively distributed across other systems with open network shares.

ZooPark

According to researchers at Kaspersky Lab, the ZooPark group has been conducting an active cyberespionage campaign in Egypt, Jordan, Morocco, Lebanon and Iran since at least 2015. Initially, the hackers distributed the simplest version of malware for Android disguised as the official Telegram application. The malware could steal only account data and contacts from the address book. A year later, their spyware was adjusted to intercept a victim's GPS location, SMS and call logs. Last year, the group reinvested into their TTP. The latest version of their malware was probably bought from developers of espionage tools – this market share is growing, especially in the Middle East. The hackers used the watering-hole technique for infection. Experts detected some news websites compromised to redirect visitors to malicious resources.

Main Events: Targeted Attacks on Banks

Lazarus

According to a McAfee report published in April, North Korean hackers have conducted a series of cyberattacks in 17 countries. The GhostSecret Operation campaign was launched in February 2018, targeting clients of cryptocurrency exchanges and financial companies. The hackers sent fake emails with attached malicious documents disguised as agreements between users and cryptocurrency exchanges. Following this, they installed a Remote Access Trojan (RAT) on a victim's computer. The malware not only stole cryptocurrency, but also spied on the victim's system. The malicious programs used by the hackers are very similar to the tools used by North Korea-linked Lazarus hackers. Moreover, the latest attacks revealed IP addresses within the same network block which was used in the Lazarus' 2014 Sony Pictures attack. In April, the Thai authorities, with support from ThaiCERT and McAfee, detected a C&C server used by the North Korean hackers as part of the GhostSecret Operation campaign in one of the Thai universities. Moreover, security experts from ESET detected Lazarus' cyberattacks on an online casino in Central America and other targets. All these attacks were conducted using similar hacking tools.

Netwire.RAT

A large-scale phishing attack distributing the Netwire RAT Trojan was tracked in April. This remote access Trojan (RAT) has capabilities to collect and send data, provide remote access to infected systems, load and execute files from the web. The emails were distributed via a mail server called lincc.org. The Trojan was loaded from a domain called diamondfoxpanel.ml. These attacks started as early as March 2, and the latest of them was detected on April 12.

Main Events: Attacks on Banks and Their Clients

Dimnie

The Financial Sector Computer Emergency Response Team (FinCERT) of the Central Bank of Russia warned financial institutions about a malicious campaign using the Dimnie Trojan to steal money and confidential information. Earlier on, the Trojan authors mainly attacked computers belonging to individuals and organizations. Using Dimnie, the hackers replaced details in payment documents and withdrew funds to their accounts. Dimnie has been active since 2014. It has evolved over time, adopting new methods for penetration and data theft. Currently, it is an almost untraceable multifunction spyware with remote administration functions. A new round in the Trojan distribution may result in large-scale losses – theoretically, cybercriminals can steal a bank's funds via SWIFT or AWS CBR (Automated Work Station Client of the Russian Central Bank).

Silence

Another FinCERT advisory was related to a phishing campaign launched by the Silence group. The attackers sent fake emails, disguised as standard requests to open correspondent accounts. They used the infrastructure of banks that had been earlier infected to send emails under their names. The payload is a Trojan called intel security.exe, which is installed on a victim's computer when the infected document is opened.

Android.BankBot.358.origin

Dr.Web specialists have reported a new Trojan called Android.BankBot.358.origin, which has allegedly infected more than 60,000 mobile devices. The malware attacks Sberbank's Russian-speaking clients, stealing money and bank card data. Some Trojan modifications can also block an infected device with a ransom message displayed. Sberbank declared that a statement from them about the threat to its clients and theft of RUB 80 million was fake. Various modifications of AndroidBankBot and their respective phishing letters have been monitored by Group-IB's CERT at least since last summer. The market of Trojans for Android mobile devices has been the most dynamic and fast growing in recent years. In 2017, damage caused by Android viruses in Russia increased by 136% and exceeded the damage caused by banking ransomware for PC by 30%.

Main Events: Attacks on Banks and Their Clients

Fake SQL

Group-IB specialists uncovered a criminal scheme used by hackers to obtain money for vulnerabilities allegedly detected on websites of financial institutions. The essence of the scheme is that the criminals share false information about the presence of an SQL injection with the security service of a target organization and show them accounts of users of the victim's website obtained using tools for brute force attacks and bought on DarkNet databases (login-password, email-password or telephone-password). Through the targeted attack, the criminals collect the data of interest on the victim's website and send a letter to the bank's security service reporting an SQL injection that allegedly allowed them to obtain a list of users. They then attempt to extort money for disclosure of information about a vulnerability that does not exist. The danger is that simultaneously the criminals can start selling the compromised accounts on underground forums.

Universal Banking Poland

Another fraudulent scheme targeting mobile banking users has been found by ESET specialists. While examining Google Play, they found a 'universal mobile app' called Universal Banking Poland targeting clients of 21 Polish banks. The app offered access to personal profiles: a user was suggested to select a bank where he had an account and then enter the login and password in a special form. The data entered were sent to a C&C server and further used by criminals to steal money from the accounts. The app bypassed two-factor authentication – users did not see an SMS sent by the bank about the withdrawal, since the attackers intercepted SMS messages. Universal Banking Poland appeared in Google Play on March 20, 2018, and was removed from the official store after a warning from ESET. However, the fake app is still available on third-party platforms.

Main Events: Threats to Cryptoindustry

Coinsecure

CSO at Coinsecure, an Indian cryptocurrency exchange, has been accused of the theft of $3.5 million in bitcoins. The suspect claims that the money was stolen from the company's bitcoin wallet due to some attack. CEO of the cryptocurrency exchange does not believe his subordinate and thinks that it is just a story invented to throw off suspicion. The recent hacking of Coinsecure affected about 11,000 people. In order to find the criminals, the cryptocurrency exchange offers about INR 20 million to any users who help it find the stolen tokens.

Rarog

A Trojan called Rarog has infected over 166,000 computers. This virus is used for hidden Monero mining on Windows. The Trojan hides the miner's work from Windows Task Manager and custom programs. Rarog not only mines the cryptocurrency, but it can also infect connected devices, download additional malicious files, update itself and even conduct DDoS attacks.

MyEtherWallet

In late April, MyEtherWallet, one of the largest Ethereum wallets, has reportedly been the victim of a DNS hack. MyEtherWallet spokesmen have confirmed that some DNS servers had been hijacked by the criminals to redirect users to a phishing website. The administration reassured users that the problem did not occur on the service side. According to the company's official message on Twitter, they are currently 'in the process of verifying which servers to get it resolved asap'.

Telegram

Fraudsters took advantage of a failure in the operation of the popular messenger Telegram. In March and April, Telegram users in Europe, Russia, the CIS and the Middle East faced several problems in the messenger's operation connected with large-scale power cuts. In just a few hours, cryptocurrency wallets advertised by fake account of the founder and head of the messenger Pavel Durov on Twitter received about $60,000.

Main Events: Ransomware

SamSam

Extortionists distributing SamSam ransomware have changed their tactics – they have started to send phishing emails to organizations, e.g., hospitals and schools, ready to pay for return of their encrypted data. Earlier on, computers were infected using a different attack vector – via hacked popular web resources. It is interesting to note that infection with BadRabbit in Russia and Ukraine in October 2017 was performed using this method.

Since the beginning of the year, a dozen US municipalities and states have been attacked by SamSam ransomware. In late March, it attacked the municipality of Atlanta, Georgia. Users had difficulties paying their bills and accessing documents there. Early this year, SamSam infected more than 2,000 computers at the Colorado Department of Transportation (DOT), Adams Memorial Hospital in Indiana, the municipality of Farmington, New Mexico, and Allscripts Professional EHR. The virus encrypted data and displayed a message with a demand for the payment of 3 bitcoins. It all started with an attack on the Hancock Health hospital in Indiana, when the management of the medical facility decided to satisfy hackers' demands and paid $55,000. It is not improbable that the purpose of the attack was sabotage rather than making money.

RansSIRIA

Researchers at MalwareHunterTeam have detected a new strain of RansSIRIA ransomware, which encrypts victims' files and then says that it would donate the ransom to Syrian refugees. It is quite widespread. In the past, fraudsters tried to use such dramatic events as the Boston Marathon bombing, MH17, Hurricane Matthew.

Main Events: Botnet and DDoS

Mirai

Early this year, at least three European financial institutions suffered DDoS attacks using a new version of the Mirai botnet consisting of 13,000 compromised IoT devices. According to the researchers, the botnet used in the first company attack was composed of 80 percent of compromised MikroTik routers and 20% various IoT devices (e.g., Apache and IIS web servers, webcams, dashcams, TVs and routers). The DDoS attacks peaked at up to 30 Gbit/sec of malicious traffic.

Necurs

Operators of Necurs, the world's largest spam botnet, consisting of 6 million infected computers worldwide, are using a new evasion technique. A potential victim receives an email containing an archived URL file. In February, the Necurs botnet was used to send spam connected with St. Valentine's Day. In April 2017, Necurs resumed its activities after a break. Over the course of recent months, it has been used for distribution of such malicious programs as Locky, Jaff, GlobeImposter, Dridex, Scarab and Trickbot.

Main Events: Tools

ATMRipper2

In April, researchers at Netskope Threat Research Labs detected a new malicious program called ATMJackpot. The experts assumed that the malware could be traced to Hong Kong and that it was still being developed. Group-IB specialists have analyzed the Trojan: although it was based on the code of the infamous malicious program ATMRipper, which was used in 2016 for attacks on ATMs in Thailand and Hong Kong, a new sample of ATMRipper2 differs from the previous version.

Treasure Hunter

Source code of Treasure Hunter, a malicious program for POS terminals, appeared on an underground forum in April 2018. The first information about Treasure Hunter appeared in 2014. The principle of its operation is similar to all POS Trojans: it obtains data from the magnetic stripe of a victim's card (Track1 + Track2) from the memory of an infected POS terminal and then transfers this information to the criminals' server. In 2015-2016, this malware was used for attacks on small banks and retail companies in the US. In spite of the fact that the malware is quite old, its publication may lead to an increase in attacks on POS terminals and the growth of compromised data and thefts.

Hidden Miner

Sales of cryptocurrency miners have recently been widespread on underground forums. Group-IB specialists have analyzed one of popular 'hidden' miners called Hidden Miner being sold by a user nicknamed Facelessronin. Installation, obtaining of privileges, suppression of traces and Monero mining are carried out using the executable files **start.zip, tinkoff.zip** and **updater.zip.** As a result, a victim's computer will be infected with the hidden miner and its User Account Control will be disabled, which may result in further malicious activity, including unauthorized access and installation of other malicious programs.

Main Events: Tools

AndyBot

An updated version of AndyBot, a Trojan for Android, appeared on an underground forum in early April. The first time AndyBot went on sale on underground forums was in November 2017. It was designed to steal money from online banking systems on Android devices. The current version dubbed Gustuff Bot contains new web fakes and is able to display fake dialogs with an icon of the original banking application. The Trojan is leased for $800 per month.

Nero banker

At about the same time, a user nicknamed Nero published an ad for a new Trojan for Android called Nero banker. This malware can intercept and send SMS, make calls, send USSD requests, show fake pages of banking applications and fake PUSH notifications. Nero banker is leased for $1,500 per month.

Osiris

In early April, an ad for a new banking Trojan called Osiris, appeared on an underground forum. The tool is leased for $2,000. The virus is designed to gain access to confidential information stored or processed in online banking systems. The specific feature of the virus is that it operates using Tor, can bypass proactive security tools, and has Anti-debugging and Anti-VM techniques and anti-emulation.

Main Events: Tools

Agent Tesla

Experts at Fortinet have detected a new variant of the famous Agent Tesla spyware. Agent Tesla is used as a keylogger to trace victims' location; it also captures screenshots and collects credentials on infected systems. Security researchers discovered it was spreading via a Microsoft Word document containing an auto-executable malicious VBA Macro. The malicious documents asked the victim to double click a blue icon to enable a “clear view.” Once clicked, it extracted an exe file from the embedded object into the system’s temporary folder and launched it. According to Fortinet, this POM.exe file is a sort of installer for the final malware.

0-day

In April, a 0-day exploit for Tieto Card Suite went on sale on an underground forum. Tieto Card Suite is a banking card processing solution by the Finnish company Tieto. Information about a dozen Russian and foreign banks using the Tieto Card Suite solution was obtained from open sources. The vulnerability type is RCE (remote code execution). The stated cost is $5,000. A year ago, the author of the announcement was observed selling exploits for the CVE 2017-0199 vulnerability. However, the business was not successful: at the time the ad was published, some samples of this exploit had already been published and the author had to stop the sales.

Lawsuits and Arrests

Webstresser

On April 24, Europol, the Dutch police and the National Crime Agency (NCA) took down webstresser.org, the world's biggest DDoS service, which helped criminals launch more than 4 million attacks. An operation, dubbed 'Power Off', allowed the authorities not only to shut down the resource but also to arrest its administrators – 6 members of the criminal group – in Scotland, Croatia, Canada and Serbia. The DDoS-for-hire service helped criminals to launch powerful cyberattacks without any special technical skills. According to Europol, webstresser.org had 136,000 registered users and the service was used extensively to conduct targeted attacks on online services of banks, government institutions and police departments.

Kane Gamble

The British hacker Kane Gamble, now 18-year-old, who hacked the mailboxes of leading US intelligence officers and security officials, including the then CIA chief John Brennan, was sentenced to two years in prison. Gamble was arrested in his own house on February 9, 2017. According to the prosecutor, the teenager was motivated by his support for the Palestinians, claiming it was because the US Government was "killing innocent people". The investigators believed that he was a founder of Crackas With Attitude, a hacker group that attacked the US security officials from October 2015 to February 2016. Two other members of the team – Andrew Otto Boggs and Justin Gray Liverman – were arrested by the FBI in September 2016 and had already been sentenced to five years in federal prisons. Gamble's counsel claimed that he is autistic.

Grant West

Grant West, an independent computer expert, was arrested by the police during his trip from Wales to London for sending phishing emails to clients of such popular companies as Uber, Apple, Sainsbury's, Ladbrokes and Just Eat. The fraudster's goal was to attract clients and convince them to disclose the details of their credit cards. To do that, he made his victims fill in online questionnaires that asked for the credit card details. After that, he sold the details of the compromised cards on the Dark Web.

Forecasts and Warnings

- The Cobalt group, on the model of Anunak, may start attacking systems connected to POS terminals and temporarily stop its attacks on banks. Their attacks will be primarily focused on companies and institutions outside the CIS.
- The most active group in the banking sector will be Silence, which has already conducted successful attacks on ATMs and card processing. These new attacks involve old but improved tools.
- Publishing of source code for Treasure Hunter, a malicious program for POS terminals, on hacker forums will result in the cloning of this malware and probably in the short-term growth of incidents due to its extensive use by low-skilled hackers.
- In the context of preparations for the 2018 FIFA World Cup in Russia, Russian companies will be attacked more often by both state-linked and financially motivated hackers. State-linked attackers may carry out sabotage and subversive actions. The main activities of financially motivated hackers will be connected with phishing attacks on individuals aimed at obtaining details of their bank cards and with infection of POS terminals.

If you wish to receive more detailed information about a specific incident, threat or criminal group,

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com